

IP Theft: Social Engineering

University of Alabama Office for Technology Development

MGT 488, Team 2, Ashley Flowers, Craig Fields, Caitlyn Rutledge, Tamiyah Kidd, Donniesha Falls, Assignment 4



THE UNIVERSITY OF
ALABAMA[®]

Culverhouse
College of Business

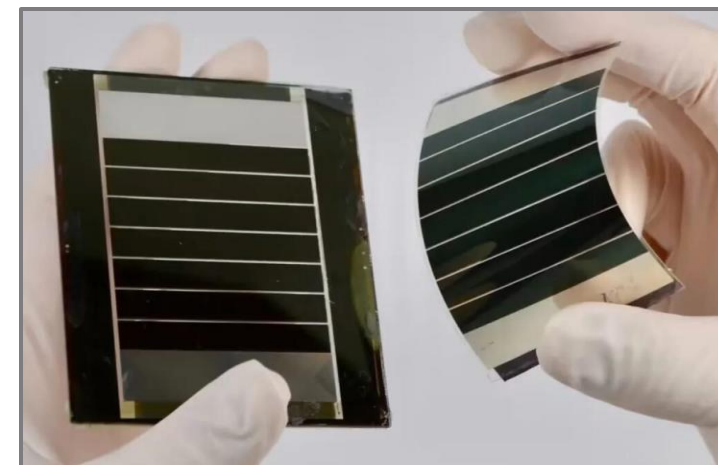
The Asset at Risk

RESEARCH ARTICLE

Perovskite Solar Cells Enabled by the Synergy of Chlorine Additive and Scalable Rapid Photonic Annealing of Multiple Stacking Layers

[Saeid Vaezsis](#), [Mohsen Ameri](#), [Pei Tang](#), [Igor Fedin](#), [Dawen Li](#) 

First published: 03 December 2025 | <https://doi.org/10.1002/pip.70039> | [VIEW METRICS](#)



\$300,000

SETO SIPS Award



U.S. DEPARTMENT
of **ENERGY**

Patents Filed at Time of Attack: **NONE**



Attack Overview – Social Engineering



Fake Persona

Posed as a researcher with real publications and institutional connections

Mr. Peter Udenze



PhD student working on perovskite solar cells, AI-assisted module fabrication, solar power system

Mr. Pei Tang



Ph.D. student working on perovskite solar cells and modules

Mr. Saeid Vaezsis



PhD student working on perovskite solar cells and modules

Phishing Link

Link routed through a fake Wiley Online login page — a popular academic journal platform

Credentials Harvested

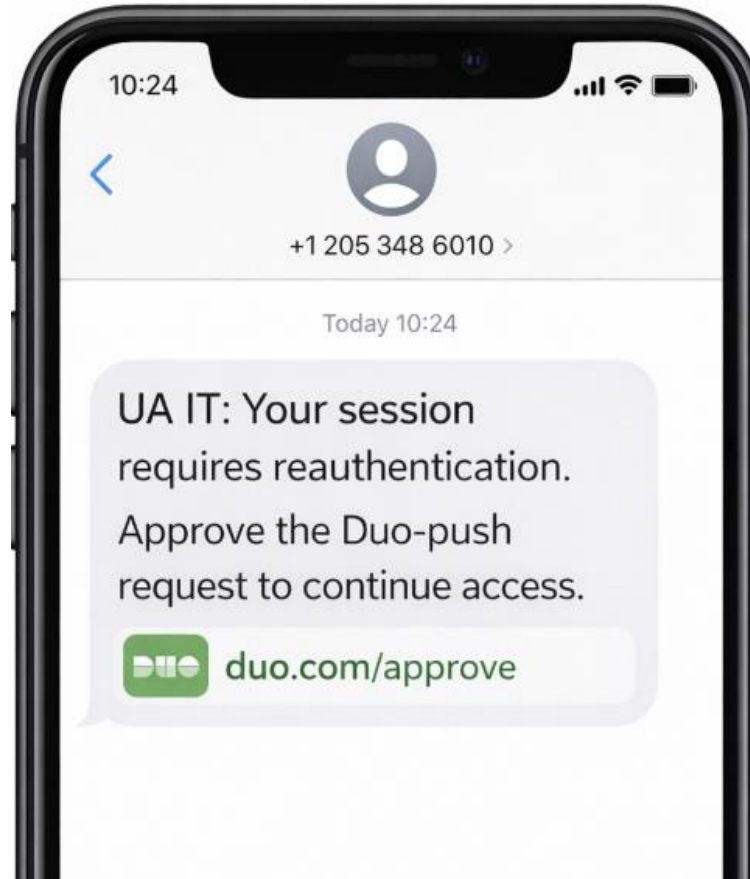
UA credentials stolen via credential stuffing

62% of Americans reuse passwords · NordPass

Attack Overview – MFA



- 1 Attacker triggers login → Duo fires
- 2 Spoofed SMS sent: "Approve to continue"
- 3 Student approves → access is granted



Text Spoofed

Appeared to come from UA — a real OIT alert

User Confusion

Student thought they triggered it — approved twice without suspicion

MFA Weakness

Approving a push you didn't initiate hands access to the attacker

Attack Overview – The Theft

Week 4 Single session · documents photographed · no trace

30 Days before UA's planned filing

Paris Convention: first to file wins in every jurisdiction



Ownership is effectively lost. China filed first. No breach of UA's perimeter was ever required.

Key Vulnerabilities

Credential Reuse

Password reuse across external platforms enabled account compromise

Insufficient Security Training

Training did not cover phishing, spoofed logins, or MFA fatigue attacks

Excessive Access

Co-inventors have broad access --> one compromised account exposed all sensitive IP

3

**Critical
Vulnerabilities
Identified**

Why No One Caught It



No detectable data exfiltration



Access used valid credentials



Academic environment enabled trust-based access (MFA)

Impact

Category	Estimated Cost	Source
Incident response	\$2.67-\$2.98M + \$30-\$120K counsel	IBM Cost of a Data Breach
Patent litigation	\$1.5-\$3M	AIPLA 2023 litigation
Patent loss	\$1.3-\$3.8M annually	\$7.02B * 1-3% adoption × 1.8% royalty (AUTM)
False Claims Act exposure	\$875K-\$1.25M FCA	Penn State + Georgia Tech (no alleged breach)
Total Possible Exposure	\$5-\$7.5 million	

Cost of prevention: under \$100,000/year.



NIST CSF 2.0 Gaps

Failure	Control	What NIST Requires
No ownership of the OTD/OIT intersection	GOVERN: GV.RR-02	Roles, responsibilities, and authorities must be established and communicated
Nation-state actors never considered in risk	IDENTIFY: ID.RA-03	Cyber threat intel must be incorporated into risk assessments
Data classified restricted; not handled as such	PROTECT: PR.DS-01	Appropriate access controls must be in place for data-at-rest
No specialized training for researchers	PROTECT: PR-AT-02	Personnel in high-risk roles must receive specialized training
MFA bypassed via spoofed text and push fatigue	PROTECT: PR.AA-03	Users must be authenticated commensurate with risk
Co-inventor held unrestricted access	PROTECT: PR.AA-05	Access permissions must be defined and reviewed, incorporating least privilege
No behavioral monitoring on OneDrive session	DETECT: DE.CM-09	Users and systems must be monitored for anomalous behavior

Incident Response

Immediate

Access Audit & Forensics

Revoke credentials, audit 60-day access logs, flag long read sessions with no edits

Legal Action

File provisional patents + notify DOE within 72 hours — delays risk all federal funding

Remediation

Least Privilege Enforcement

Scoped, read-only, time-expiring co-inventor sessions only

Enhanced Monitoring

Automated surveillance flagging filings that match UA's patent portfolio

Governance & Oversight

Expand ORSEC mandate to include active IP monitoring across OTD and OIT

Preventative Measures

Enhanced Security Awareness Training

Role-based training covering MFA fatigue, spoofed login pages, fabricated personas. Built on existing NSF SCORM files.

~\$6,000 *one-time*

OneDrive Behavioral Analytics

Detects anomalous access patterns — long read sessions with no edits — across researcher OneDrive accounts.

\$36K-\$72K *annually*

Questel Orbit Patent Monitoring

Automated surveillance flagging CNIPA and USPTO filings that match UA's active patent portfolio

\$15,000 *annually*

YubiKey FIDO2 Hardware Keys

Phishing-resistant hardware MFA for high-risk researchers

\$22-\$45K *one-time*

Year 1: **\$88K-\$184K** Ongoing: **\$51K-\$87K**

Cost was more than **50 years** of prevention budget!.



Thank You!
Questions?